

3-2 Activity

Information Security Policy

Francisco Sousa

SNHU

IT 253

Instructor Scott Maples, MSITM

03/22/26

FDIC Information Technology Acceptable Use Review

Question 1: What laws or regulations may have influenced this policy's development?

The FDIC Information Technology Acceptable Use Policy, Directive 1300.04, revised January 2023, was shaped by several laws and regulations. Executive Order 13513 directly influenced the prohibition on texting while driving during official government business. Title 5 of the Code of Federal Regulations, Part 2635, shaped the policy's professional conduct requirements, including the prohibition on using FDIC IT resources for outside business activities. The Federal Information Security Modernization Act (FISMA) plays an underlying role as well, requiring federal agencies to develop agency-wide information security programs, which this directive supports through its monitoring, authorized use, and disciplinary action provisions (Whitman & Mattord, 2021). The Gramm-Leach-Bliley Act, which governs how financial institutions protect customer data, also informs the policy's emphasis on protecting sensitive information throughout its prohibited uses section (FDIC, 2023). As Gordon et al. (2020) note, regulatory frameworks like FISMA and NIST directly shape how agencies structure their security programs, and this directive reflects that influence clearly.

Question 2: What audience was the policy specifically intended for?

The policy applies to all authorized users of FDIC IT resources, including employees, contractors, and any other individuals with access to FDIC systems (FDIC, 2023). This broad scope makes sense given that the FDIC handles sensitive financial regulatory data and bank examination records. Anyone with system access, permanent staff or contracted vendor, represents a potential security risk. The policy also assigns specific responsibilities to the Chief Information Officer, Chief Information Security Officer, supervisors, and contracting officers,

distributing accountability across the organization. Ismail et al. (2017) emphasize that clearly defined roles and responsibilities are essential to any effective security policy, and the FDIC's approach reflects that principle directly.

Question 3: What elements would you recommend to enhance this policy?

While Directive 1300.04 provides a solid foundation, several gaps stand out. First, the policy contains no explicit password management requirements. Policies governing IT use should incorporate minimum password length, complexity, and rotation standards to remove ambiguity for users (Khachatryan, 2025). Second, there is no multi-factor authentication requirement despite MFA being one of the most effective controls against unauthorized access (NIST, 2020). Third, while the policy references incident reporting through separate directives, a brief summary of response expectations within the document itself would make it more self-contained. Ismail et al. (2017) argue that users should be able to understand their core obligations without navigating multiple documents. Finally, adding a vendor risk assessment requirement would address third-party threats by ensuring contractors are evaluated for security compliance before and during system access.

References

Federal Deposit Insurance Corporation. (2023). *FDIC Directive 1300.04: Information technology acceptable use*. <https://www.fdic.gov/formsdocuments/d1300-04.pdf>

Gordon, L. A., Loeb, M. P., & Zhou, L. (2020). Integrating cost–benefit analysis into the NIST Cybersecurity Framework via the Gordon–Loeb Model. *Journal of Cybersecurity*, 6(1), 1–8. <https://doi.org/10.1093/cybsec/tyaa005><https://doi.org/10.1093/cybsec/tyaa005>

Ismail, W. B. W., Widyarto, S., Ahmad, R. A. T. R., & Ghani, K. A. (2017). A generic framework for information security policy development. *2017 4th International Conference on Electrical Engineering, Computer Science and Informatics (EECSI)*, 1–6. <https://doi.org/10.1109/EECSI.2017.8239132>

Khachatryan, A. (2025, August 20). *10 information security policies every organization should implement*. Syteca. <https://www.syteca.com/en/blog/information-security-policies><https://www.syteca.com/en/blog/information-security-policies>

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5><https://doi.org/10.6028/NIST.SP.800-53r5>

Whitman, M. E., & Mattord, H. J. (2021). *Principles of information security* (7th ed.). Cengage Learning.